



Red Salud Armenia E.S.E.

PÁ CUIDAR DE TODOS

**Plan de Contingencia Sistemas de información
Anexo 1**

Tabla de contenido

<u>INTRODUCCIÓN</u>	7
<u>1. OBJETIVOS</u>	7
<u>1.1. Objetivo general.</u>	7
<u>1.2. Objetivos específicos.</u>	8
<u>2. PLANIFICACIÓN:</u>	9
<u>3. ALCANCE</u>	10
<u>4. DEFINICIONES</u>	10
<u>4.1. ¿Qué es un sistema de información?</u>	10
<u>4.2. ¿Qué es un desastre informático?</u>	11
<u>4.3. ¿Qué es una contingencia?</u>	11
<u>4.4. ¿Qué es un plan de contingencia?</u>	11
<u>4.5. ¿Por qué se necesita un plan de contingencia?</u>	12
<u>4.6. ¿Acciones a ser consideradas?</u>	¡Error! Marcador no definido.
<u>4.8. Plan de Prevención:</u>	13
<u>4.9. Plan de Ejecución:</u>	13
<u>4.10. Plan de Recuperación:</u>	13
<u>4.11. El Plan de Pruebas:</u>	¡Error! Marcador no definido.
<u>5. MÉTODOS DE PROTECCIÓN</u>	14
<u>6. AMENZAS DE SEGURIDAD</u>	14
<u>7. PRIORIDAD DE ASPECTOS CRÍTICOS EN LOS APLICATIVOS INFORMÁTICOS</u>	17
<u>7.1. TENEMOS COMO PRIORIDAD LOS SIGUIENTES APLICATIVOS INFORMÁTICOS:</u>	18
<u>8. RESPONSABLE DEL PLAN DE CONTINGENCIA</u>	18

9.	<u>MARCO METODOLOGICO PARA EL PLAN DE CONTINGENCIA</u>	19
10.	<u>IMPLEMENTACIÓN DE RECUPERACIÓN</u>	20
10.1.	<u>IDENTIFICACIÓN DE RIESGOS</u>	20
10.2.	<u>SOLUCIONES A LOS PROBLEMAS PRESENTADOS</u>	21
10.2.1.	<u>ROBO DE EQUIPOS, DAÑOS POR SABOTAJE O DAÑOS POR MAL USO:</u>	21
10.2.2.	<u>CORTE DE ENERGÍA ELÉCTRICA:</u>	22
10.2.3.	<u>FUGAS DE AGUA Y HUMEDADES:</u>	23
10.2.4.	<u>TERREMOTO:</u>	23
10.2.5.	<u>INCENDIO:</u>	23
10.2.6.	<u>CORTES O GOLPES EN EL CABLE UTP O EL CABLE ELÉCTRICO:</u>	24
10.2.7.	<u>DESCARGAS ELÉCTRICAS EN LAS ANTENAS:</u>	24
10.2.8.	<u>SOBRECARGA EN LA RED ELÉCTRICA REGULADA POR CONEXIÓN DE EQUIPOS NO AUTORIZADOS:</u>	24
10.2.9.	<u>VIRUS INFORMÁTICOS:</u>	24
10.2.10.	<u>DESCONEXIÓN DEL SERVIDOR CON EL CLIENTE O VICEVERSA:</u>	25
10.2.11.	<u>BLOQUEO EN EL MOTOR DE BASES DE DATOS:</u>	26
10.2.12.	<u>FALLAS O PÉRDIDA DEL SERVIDOR:</u>	26
10.2.13.	<u>PÉRDIDA POR ELIMINACIÓN DE INFORMACIÓN:</u>	27
10.2.14.	<u>SABOTAJE O DAÑO EN SOFTWARE OMEGA O EN SU SERVIDOR:</u>	27
10.2.15.	<u>PERDIDA DE LA CONEXIÓN DE LA INTERNET:</u>	28
11.	<u>ESTRATEGIAS DE RECUPERACIÓN</u>	28

<u>12.</u>	<u>PREVENCIÓN Y SEGURIDAD</u>	28
<u>13.</u>	<u>ACTIVACIÓN DE PROCESOS MANUALES</u>	29

RESUMEN

Un porcentaje muy alto de los incumplimientos TI, es debido a la caída de infraestructura Hardware o Software, la cual supone una afectación en el servicio sin previo aviso. De forma proactiva se establecen planes y herramientas que mejoren la capacidad del entorno, pero de forma reactiva, están los llamados Planes de Contingencia para tecnologías de la información (TI).



Un plan de contingencia es un instrumento de gestión para el buen gobierno de las Tecnología de la Información y las comunicaciones en el dominio del soporte y desempeño. Estos planes de contingencia contienen las medidas técnicas, humanas y organizativas necesarias para garantizar la continuidad de la empresa. Es un caso particular de plan de continuidad de la empresa, pero dada la importancia actual de las tecnologías modernas, el plan de contingencias es el más relevante. El objetivo de este documento es explicar que es un plan de contingencia, el porqué de su importancia y el cómo de su preparación. La mejora de dicho plan se basa principalmente en la automatización de las acciones.

PLAN DE CONTINGENCIA SISTEMAS DE INFORMACION



Es un conjunto de acciones planificadas que ejecutara Red Salud Armenia ESE ante la posible pérdida de información, destrucción, robo y otras amenazas, que presenten los equipos de cómputo, la red o el sistema de información.

En una empresa es importante organizar un plan de contingencia, debemos crear, preparar, organizar la implementación de un completo Plan de Contingencia Informático. Cualquier empresa que tenga un sistema de redes, ordenadores, periféricos, servidores, bases de datos, dispositivos, accesorios, están expuestos a riesgo y puede ser fuente de problemas. El Hardware, el Software están expuestos a diversos Factores de Riesgo Humano, naturales y Físicos. Analizando este tipo de problemas nos vemos en la obligación de retroalimentar los planes de seguridad de la información.

Podemos presentar pérdidas catastróficas en los discos duros, pueden ser por desastres como, incendios, terremoto, sabotajes entre o por fallas técnicas que pueden ser errores humanos o fallas técnicas los cuales se presentan físico irreparable. Por esto es importante contar con un plan de contingencia adecuado el cual ayude a la empresa a recuperarse rápidamente y poder procesar la información.

INTRODUCCIÓN

El plan de contingencia implica un análisis de los riesgos a los cuales está expuesto el sistema informático o alguno de sus componentes, como son: los equipos de cómputo, los datos contenidos en ellos, los medios de almacenamiento y transmisión, las redes eléctricas reguladas y las redes de cableado estructurado e inalámbricas. Éste análisis de riesgos se ha realizado con el fin de determinar cómo reducir su posibilidad de ocurrencia y los procedimientos a seguir en caso de presentarse problemas.

7

El plan de contingencia incluye un plan de recuperación del sistema de información en caso de desastres, que tiene como objetivo restaurar las bases de datos, los gestores de bases de datos, y la información de registros clínicos, entre otros.

El plan de contingencia incluye un plan de recuperación del sistema de información en caso de desastres, que tiene como objetivo restaurar las bases de datos, los gestores de bases de datos, y la información de registros clínicos, entre otros.

Para que nuestra empresa Red Salud Armenia E.S.E, pueda cumplir con este plan de contingencia, es importante manejar la información, por esto necesitamos garantizar tiempos mínimos para no originar distorsiones al funcionamiento normal de nuestros servicios y no sean mayores nuestros costos de operación, porque si esto se presenta con un tiempo mayor se para el servicio y dejamos de facturar, si no hay información de los usuarios el profesional de salud no podrá atender los pacientes y esto acarrea problemas legales para la empresa, la información es muy importante para la atención del usuario y la toma de sesiones de la empresa. Sabiendo esto es importante saber cómo actuar ante cualquier situación, que recursos necesitamos para poder seguir funcionando y poder cumplir con las actividades de la empresa.

OBJETIVOS

Objetivo general.

El objetivo de este documento es explicar que es un plan de contingencia, el porqué de su importancia y el cómo de su preparación, El plan de contingencia garantiza la continuidad de las operaciones en el proceso de Sistemas de información Red Salud Armenia E.S.E. a través del desarrollo ágil y estructurado de un conjunto de medidas que permiten tener cursos alternativos de acción cuando el sistema informático es afectado parcial o totalmente por daños o amenazas, para mantener el procesamiento electrónico de datos en aquellos procesos que son fundamentales para alcanzar los objetivos de Red Salud Armenia E.S.E.

Debemos aplicar la forma eficiente e inmediata como se activarán todas las áreas de Red Salud ESE Armenia, en función de una emergencia interna o externa, minimizando con ello las pérdidas de Información, a la vez que se asegura la continuidad del servicio.

Realizaremos este plan para realiza el análisis de impactos económicos, técnicos, legales, determinar sus efectos en las distintas funciones de la ESE y en sus resultados. En definitiva, conoceremos y gestionaremos los riesgos para reducir al máximo su posible impacto negativo.

Objetivos Específicos

- Proteger los activos informáticos de la E.S.E.
- Asegurar la continuidad de las operaciones después de una falla parcial o total del sistema informático.
- Garantizar la continuidad de los procesos críticos dentro de los márgenes de tiempo tolerables.
- Minimizar el proceso de toma de decisiones durante una contingencia.
- Reducir los efectos negativos ocasionados por el caos.
- Cumplir con los requerimientos legales contractuales y gubernamentales.
- Eliminar las necesidades de desarrollar nuevos procedimientos durante la contingencia.
- Minimizar la posibilidad de pérdida de información crítica para los servicios.
- Implementar el plan de contingencia para emergencias de origen interna y externa.
- Identificar las amenazas y analizar la vulnerabilidad para definir los niveles de riesgo de la ESE
- Brindar las herramientas operativas que permitan la vigencia del plan para control de emergencias ante la pérdida de información en la institución.
- Evaluar la eficiencia y el mejoramiento de los controles y protecciones existentes ante la pérdida de información, además de la preparación de los en actividades antes, durante y después de la emergencia.
- Garantizar la continuidad en la prestación del servicio
- Definir cuáles son los equipos, edificaciones y recursos institucionales, para lograr un rendimiento óptimo frente a una situación de emergencia o desastre en los equipos de cómputo, red o sistema de información.
- Realizar el inventario de los recursos físico disponible para la atención de emergencia.

- Establecer un procedimiento de evacuación para todos los empleados y usuarios de la ESE.

PLANIFICACIÓN



9

En Red Salud ESE Armenia se trabajan procesos administrativos, financieros y asistenciales.

En los procesos financieros el trabajo se realiza de forma local en cada uno de los terminales de cómputo y en igual proporción en el

sistema de información Dinámica Gerencial Hospitalaria en sus versiones Fox y .Net. En caso de falla total o parcial del sistema de información, se restablecen las copias de seguridad del sistema de información.

En los procesos administrativos la mayoría de las actividades se realizan en el software ofimático de forma local en cada terminal, por lo que una falla en sistema de información no afecta el normal desarrollo del área, sin embargo, la pérdida de conexión de red afectaría el acceso a internet y archivos compartidos.

El proceso de facturación compromete directamente actividades del área financiera y asistencial, por tal motivo debe aplicar tres acciones que se describen en el numeral 9 de este plan de contingencia.

El proceso asistencial comprende actividades del auxiliar de filtro, del proceso de archivo, de la coordinación de los centros de salud, de la coordinación de los servicios y del personal asistencial, y debe ejecutar las acciones descritas en el numeral 9 de este plan de contingencia

ALCANCE

El presente plan se diseña e implementa para las instalaciones de Red Salud ESE Armenia y determina la gestión para el caso de emergencias de origen interno o externo frente a los equipos de cómputo, red, sistema de información Etc. De acuerdo con un análisis del riesgo.

10



Esta directiva será administrada por el área de sistemas de información y mantenimiento de sistemas (administra, opera y supervisa los sistemas informáticos, equipos de cómputo, equipos de redes de la institución).

DEFINICIONES

¿Qué es un sistema de información?

Un sistema de información es un conjunto de elementos orientados al tratamiento y administración de datos e información, organizados y listos para su uso posterior, generados para cubrir una necesidad o un objetivo. Dichos elementos formarán parte de alguna de las siguientes categorías: Personas; Datos; Actividades o técnicas de trabajo; Recursos materiales en general (generalmente recursos informáticos y de comunicación, aunque no necesariamente). Un Sistema Informático utiliza ordenadores para almacenar los datos de una organización y ponerlos a disposición de su personal. Pueden ser tan simples como en el que una persona tiene una computadora y le introduce datos, los datos pueden ser registros simples como ventas diarias, se produce una entrada por cada venta. Sin embargo,

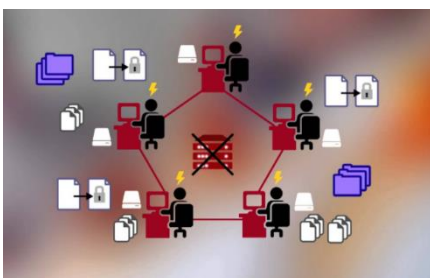
la mayor parte de los sistemas son más complejos que el enunciado anteriormente. Normalmente una organización tiene más de un sistema informático y redes de computadoras para soportar las diferentes funciones de la organización, ya sean servicios, ventas, recursos humanos, contabilidad, producción, inventario, etc. Los sistemas de información tienen muchas cosas en común. La mayoría de ellos están formados por personas, equipos y procedimientos. Al conjugar una serie de elementos como hombres y computadoras se hace imprescindible tomar medidas que nos permitan una continuidad en la operatividad de los sistemas para no ver afectados los objetivos de las mismas y no perder la inversión de costos, tiempo y beneficio.

¿Qué es un desastre informático?

Se considera como la interrupción prolongada o definitiva de los recursos informáticos y de comunicación de Red salud Armenia E.S.E, que no puede remediarse dentro de un periodo predeterminado aceptable y que necesita el uso de un sitio o equipo alterno como soporte para su recuperación.



¿Qué es una contingencia?



Se define como la posibilidad de que algo suceda o no suceda; pero más que su semántica no atañe la reanudación de las actividades ante una calamidad, la cual puede ser una de las situaciones más difíciles con las que una organización deba enfrentarse. Tras un desastre, es probable que no

haya posibilidades de regresar al lugar de trabajo o que no se disponga de ninguno de los recursos acostumbrados. Incluso, es posible que no se pueda contar con todo el personal.

¿Qué es un plan de contingencia?

Un plan de contingencia es el proceso de planear y documentar anticipadamente qué hacer al momento de presentarse un evento catastrófico sobre la empresa y saber identificar si por su magnitud es necesario recuperar cualquier tipo de red o el sistema informático. En resumen, es el conjunto de procedimientos



y estrategias definidos para asegurar la reanudación oportuna y ordenada de los procesos en Red Salud Armenia E.S.E. generando un impacto mínimo al proceso de atención.

Un plan de contingencia es un instrumento de gestión para el buen gobierno de las Tecnología de la Información y las comunicaciones en el dominio del soporte y desempeño. Estos planes de contingencia contienen las medidas técnicas, humanas y organizativas necesarias para garantizar la continuidad de la empresa y las operaciones de un proyecto. El plan de contingencias es el más relevante.

12

¿Por qué se necesita un plan de contingencia?

Es necesario porque nos permite dar respuesta efectiva al momento en que se presente algún tipo de desastre informático, ayudándonos a minimizar los efectos de la situación presentada.



¿Acciones a ser consideradas?

Antes: como hacer un plan de respaldo o de prevención para mitigar los incidentes.

Durante: como un plan de emergencia y/o ejecución en el momento de presentarse el incidente.

Después: como un plan de recuperación una vez superado el incidente para regresar al estado previo a la contingencia.

El Plan de Contingencia permite minimizar las consecuencias en caso de incidente con el fin de reanudar las operaciones en el menor tiempo posible

en forma eficiente y oportuna. El término “incidente” en este contexto será entendido como la interrupción de las condiciones normales de operación en cualquier proceso informático en la MPCH.

Plan de Prevención

13

Es el conjunto de acciones, decisiones y comprobaciones orientadas a prevenir la presencia de un evento con el propósito de disminuir y mitigar la probabilidad de ocurrencia del mismo en los factores identificados en el presente plan. El plan de prevención es la parte principal del Plan de Contingencia de Sistemas de Información porque permite aminorar y atenuar la probabilidad de ocurrencia de un estado de contingencia.

Plan de Ejecución

Es el conjunto detallado de acciones a realizar en el momento que se presenta el incidente de contingencia y que activa un mecanismo alternativo que permitirá reemplazar a la actividad normal cuando este no se encuentra disponible. Las acciones descritas dentro del plan de ejecución deben ser completamente claras y definidas de forma tal que sean de conocimiento y entendimiento inequívoco del personal involucrado en atender la contingencia.

Plan de Recuperación

Es el conjunto de acciones que tienen por objetivo restablecer oportunamente la capacidad de las operaciones, procesos y recursos del servicio que fueron afectados por un evento de contingencia. los planes en cada una de las etapas descritas, logrando así tener un documento dinámico.



MÉTODOS DE PROTECCIÓN

Siguiendo estos sencillos consejos se puede aumentar considerablemente la seguridad de una computadora, algunos son:

- Tener el sistema operativo y el navegador web actualizados.
- Tener instalado un antivirus y un firewall y configurarlos para que se actualicen automáticamente de forma regular ya que cada día aparecen nuevas amenazas.
- Utilizar una cuenta de usuario con privilegios limitados, la cuenta de administrador solo debe utilizarse cuando sea necesario cambiar la configuración o instalar un nuevo software.
- Tener precaución al ejecutar software procedente de Internet o de medios extraíbles como CD o memorias USB. Es importante asegurarse que proceden de algún sitio de confianza.
- Evitar descargar software de redes P2P, ya que realmente no se sabe su contenido ni su procedencia.
- Desactivar la interpretación de Visual Basic Script y permitir Java Script, ActiveX y cookies sólo en páginas web de confianza.
- Utilizar contraseñas de alta seguridad para evitar ataques de diccionario.
- Es recomendable hacer copias de respaldo regularmente de los documentos importantes, a medios extraíbles como CD o DVDs para poderlos recuperar en caso de infección por parte de algún malware.
- Guardar información importante de trabajo en la nube (Google Drive), y hacer una copia cada determinado tiempo, solicitar a sistemas que guarde la información en los Discos duros.

AMENZAS DE SEGURIDAD

Se entiende por AMENAZA una condición del entorno del sistema de información (personas, maquinas Etc.) que dada una oportunidad podría dar lugar a que se genere una VIOLACION DE SEGURIDAD.

La violación de seguridad son contrapartes a la certificación de un sistema seguro y se clasifican en

- Confidencialidad
- Integridad
- Disponibilidad
- Uso legítimo



LAS POLITICAS DE SEGURIDAD Y EL ANALISIS DE RIESGOS, habrán identificado las amenazas que deberán de ser contrarrestadas dependiendo del diseño del sistema de seguridad especificando, los servidores y mecanismos de seguridad necesarios para prevenir eventos o enfrentar contingencias. Específicamente su captura, transformación, almacenamiento, protección y recuperación.

PLAN DE TRATAMIENTO DE RIESGOS DE SEGURIDAD Y PRIVACIDAD DE LA INFORMACION

Red Salud Armenia E.S.E. dentro de sus lineamientos de Sistemas de Información tiene establecido primordialmente tener la seguridad y la privacidad de la información de los usuarios que de alguna u otra manera interactúan con el Sistema de Información o mediante cualquier tipo de acceso a los datos institucionales desde alguna estación de trabajo o dispositivo.

Red Salud Armenia E.S.E. en busca de la mejora continua implementa un método lógico y sistemático que permita identificar, analizar, evaluar, tratar, monitorear y comunicar los riesgos asociados el manejo de la información institucional, para lograr que estos no afecten de una manera relevante a la misma.

La institución en su quehacer diario utiliza TIC en cuanto a captura, procesamiento y reporte de información tanto internamente como externamente para comunicarse con los diferentes actores del sistema de salud, lo cual implica que la institución sea vulnerable a ataques mal intencionados o mala manipulación de la información lo que acarrea problemas económicos, legales, y administrativos por lo cual este documento busca establecer un línea de trabajo que permita a la entidad sortear los riesgos que lo rodean y lograr que su información este segura.

Identificación del Riesgo				Valoración del Riesgo de Corrupción										Monitoreo y revisión			
Proceso / Objetivo	Causa	Riesgo	Consecuencia	Análisis del Riesgo			Valoración del Riesgo							Fecha	Acciones	Responsable	Indicador
				Riesgo Inherente			Riesgo Residual										
				Probabilidad	Impacto	Zona de Riesgo	Controles	Probabilidad	Impacto	Zona de Riesgo	Periodo de ejecución	Acciones	Registro				
Proceso: Sistema de Información Objetivo: Definir e implementar estrategias TI (Tecnologías de Información) alineados con el Plan de Desarrollo de la ESE que permitan orientar la administración de las tecnologías de la información dentro de los lineamientos de gobierno digital y mejores prácticas	Falta total del servidor Principal de Base de Datos del Hospital	Pérdida de información de los bases de datos del Sistema de Información Institucional Dinámico General del Nst	*Pérdida de información de los bases de datos del Sistema de Información *Problemas para realizar labores con normalidad en el sistema	Posible (4)	Mayor (10)	Alta (40)	* Realizar Copias de seguridad de los bases de datos del sistema de información * Comparar copias de seguridad realizadas * Forzar en servidor alguno de respaldo	Rara vez (1)	Mayor (10)	Bajo (10)	2020	Garantizar que el 100% de las copias de seguridad se realicen según lo establecido en el manual de copia de seguridad de la institución	Copias de seguridad en el servidor Principal	30 de Abril de 2020 31 de Agosto de 2020 31 de Diciembre de 2020	Verificar que el 100% de las copias de seguridad se realicen según lo establecido	Lider Proceso Sistema de Información	Copias de seguridad realizadas Total de copias de seguridad programadas
Proceso: Sistema de Información Objetivo: Definir e implementar estrategias TI (Tecnologías de Información) alineados con el Plan de Desarrollo de la ESE que permitan orientar la administración de las tecnologías de la información dentro de los lineamientos de gobierno digital y mejores prácticas	Fallo en la red Red Salud Armenia E.S.E.	Falla general de la red de datos del hospital	*Inconvenientes para la atención de los usuarios *Problemas para realizar labores con normalidad en el sistema de información en las áreas Administrativa, Financiera y Asistencial.	Posible (4)	Mayor (10)	Alta (40)	* Realizar respaldos diarios al estado de la red de datos del hospital	Posible (3)	Mayor (10)	Alta (30)	2020	Garantizar que el 97% del tiempo se tenga disponibilidad de la red de datos del hospital	Formato de registro de interrupción en la red de datos de información	30 de Abril de 2020 31 de Agosto de 2020 31 de Diciembre de 2020	Verificar que el 97% del tiempo se tenga disponibilidad de la red de datos de información	Lider Proceso Sistema de Información	Total tiempo fallo red de datos Total tiempo disponible red de datos
Proceso: Sistema de Información Objetivo: Definir e implementar estrategias TI (Tecnologías de Información) alineados con el Plan de Desarrollo de la ESE que permitan orientar la administración de las tecnologías de la información dentro de los lineamientos de gobierno digital y mejores prácticas	Incurción de Malware Software Maliciosos Virus informáticos, gusanos, troyanos, spyware, rootkits y ransomware.	Pérdida de información de servidores y equipos de cómputo. Exfiltración, Secuestro y/o Manipulación de la información digital del Hospital	Pérdida de información administrativa, financiera y asistencia de los servidores y equipos de cómputo. Inconvenientes para realización de los registros administrativos y asistencia en el sistema de información. Problemas para realizar labores con normalidad en el sistema de información. Pérdidas económicas. Sanciones Legales	Improbable (2)	Moderado (5)	Bajo (10)	Realizar Copias de seguridad de los bases de datos del sistema de información tanto locales como en la nube. Software de Antivirus Licenciado y Actualizado en los servidores y equipos de cómputo. Mantenimiento preventivo y correctivo de computadores y equipo de red de datos. Implementación de UTM - Gestion	Rara Vez (1)	Mayor (10)	Bajo (10)	2020	El líder del proceso de sistema de información Garantiza que el 100% de las copias de seguridad se realicen según lo establecido en el manual de copia de seguridad de la institución. Contrato Anual del Software de Antivirus Cronograma de mantenimiento preventivo. Contrato de UTM con empresa proveedora.	* Copias de seguridad en el servidor Principal y la nube. * Contrato de Antivirus y UTM. * Registro de mantenimiento preventivo.	30 de Abril de 2020 31 de Agosto de 2020 31 de Diciembre de 2020	Verificar el cumplimiento de las acciones implementadas	Lider Proceso Sistema de Información	Acciones de control realizadas Total de acciones de control implementadas
Proceso: Sistema de Información Objetivo: Definir e implementar estrategias TI (Tecnologías de Información) alineados con el Plan de Desarrollo de la ESE que permitan orientar la administración de las tecnologías de la información dentro de los lineamientos de gobierno digital y mejores prácticas	Vulnerabilidad, explotación o uso indebido de la información. Descenso de la política de seguridad y privacidad de la información	Manipulación de los datos e información de los equipos de cómputo. Inconvenientes derivados del uso de los equipos de cómputo. Pérdidas económicas. Sanciones Legales	Manipulación de información administrativa, financiera y asistencia de los equipos de cómputo. Pérdidas económicas. Sanciones Legales	Posible (4)	Moderado (5)	Moderado (15)	Política de seguridad y Privacidad de la información. Directorio Activo. Software de Antivirus Licenciado. Implementación de UTM - Gestion Utilizado de Antivirus Seguiniento a Privilegios y Análisis de la información	Rara Vez (1)	Mayor (10)	Bajo (10)	2020	El líder del proceso de sistema de información debe proponer por que los usuarios conozcan las Políticas de seguridad, y Privacidad de la información. Contrato Anual del Software de Antivirus Cronograma de mantenimiento preventivo. Contrato de UTM con empresa proveedora.	* Listas de Asistencias * Contrato de Antivirus y UTM. * Registro de mantenimiento preventivo.	30 de Abril de 2020 31 de Agosto de 2020 31 de Diciembre de 2020	Verificar conocimiento y aplicación de las políticas de seguridad y privacidad de la información	Lider Proceso Sistema de Información	No. De implementaciones realizadas Total de usuarios de la entidad

Valoración del Riesgo:

Se mide en cuanto a probabilidad e impacto para obtener un dato cuantitativo que permita su comparación y priorización, como se muestra en las siguientes escalas de valoración:

P R O B A B I L I D A D	Resultados de la calificación del Riesgo de Corrupción				
	Probabilidad	Puntaje	Zonas de riesgo de corrupción		
	Casi Seguro	5	25 Moderada	50 Alta	100 Extrema
	Probable	4	20 Moderada	40 Alta	80 Extrema
	Posible	3	15 Moderada	30 Alta	60 Extrema
	Improbable	2	10 Baja	20 Moderada	40 Alta
	Rara vez	1	5 Baja	10 Baja	20 Moderada
	Impacto		Moderado	Mayor	Catastrófico
	Puntaje		5	10	20
	IMPACTO				

PRIORIDAD DE ASPECTOS CRÍTICOS EN LOS APLICATIVOS INFORMÁTICOS



Se define como aspectos críticos en los aplicativos informáticos los más importantes para continuar con la normal prestación del servicio, aquellos afectan directamente el proceso de atención. Debido a que su prioridad es de importancia vital para la actividad institucional, se determinó que el aplicativo Dinámica Gerencial .Net es la piedra angular del sistema de información y por tanto los esfuerzos deben estar enfocados a restablecer su funcionamiento. Para el óptimo funcionamiento del sistema de información es necesario que se

cuenta con una copia vigente de las bases de datos, recuperada de las copias de seguridad que se hacen al servidor. Estas bases de datos son el aspecto crítico del sistema de información, pues en ellas se almacenan los datos clínicos, financieros, inventarios y de nómina, entre otros.

Tenemos como prioridad los siguientes aplicativos informáticos

Según la importancia y frecuencia de uso del software institucional, en caso de calamidad o desastre los aplicativos deben restablecerse en el siguiente orden:

1. Microsoft SQL Server
2. Dinámica Gerencial .Net
3. Eset File Security o Eset Endpoint Security
4. Cisco ADSM 6.0
5. Microsoft Office u OpenOffice
6. Dinamica Gerencial Fox
7. Simbad
8. Jzip, Adobe Acrobat Reader, Message Popup II.
9. Software de Impresión.
10. Facturación electronica

RESPONSABLE DEL PLAN DE CONTINGENCIA

La planificación, desarrollo, verificación, control e implementación del Plan de Contingencia del Sistema Informático de Red Salud Armenia E.S.E, será responsabilidad del grupo de trabajo de Sistemas de Información en cabeza del líder del proceso.

MARCO METODOLOGICO PARA EL PLAN DE CONTINGENCIA

Cuando se detecte una falla en el desarrollo normal del sistema de información, el funcionario debe informar a su jefe de área para que a su vez este corrobore con el líder de la oficina de sistemas, que efectivamente se trata de una falla informática. El grupo de trabajo de la oficina de sistemas evaluará si el daño se presenta en una parte o en la totalidad de la red e informará a los coordinadores de centro y/o líderes de los procesos afectados para que comiencen a utilizar los procedimientos y

19



formatos manuales que se describen en el numeral 15 de este documento, de acuerdo a la naturaleza de la actividad que se desarrolle. En caso de un siniestro, un desastre natural o de la pérdida total de comunicación entre los centros de salud y el hospital del sur, los coordinadores de centro o líderes de proceso tienen la autonomía para definir en qué momento se deben comenzar a utilizar los procedimientos y formatos manuales.

El área asistencial incluye los servicios de urgencias, hospitalización, sala de partos, quirófano y central de materiales. La iniciación de los procesos manuales en estos servicios debe ser autorizada por el líder o coordinador de servicio, quien verifica con el área de sistemas la gravedad del daño y el tiempo estimado para solucionarlo; en caso de que la falla no se pueda solucionar oportunamente, el líder o coordinador de proceso da la directriz al grupo de trabajo, informando que se deben registrar las atenciones de forma manual y suministrando los insumos requeridos para tal fin.

En el caso del servicio de consulta externa, las agendas de las citas programadas (médicas, odontológicas, enfermería y otros) deben ser impresas desde el día anterior por parte del facturador. En el momento en el que falle el sistema de

información, los facturadores tienen los talonarios para facturar de forma manual y posteriormente los datos se ingresan al sistema. Cuando el sistema se ha restablecido el facturador ingresa los RIPS que el profesional de la salud diligenció en el formato durante la consulta. El auxiliar de filtro y la Coordinadora, son las personas encargadas de informar a los usuarios que el sistema de información presenta fallas, y por tal motivo el proceso de facturación y la consulta se retrasan. El auxiliar de filtro debe suministrar al profesional de la salud la historia clínica física de los pacientes, cuando se trata de una consulta de riesgo cardiovascular, crecimiento y desarrollo y/o tratamiento odontológico. El auxiliar de filtro debe suministrar profesional el formato de evolución para la consulta de medicina general. Al terminar la jornada el auxiliar debe revisar que la hoja de evolución haya sido completamente diligenciada por el profesional de la salud. Posteriormente la auxiliar entrega en la oficina de archivo las hojas de evolución diligenciadas por el profesional de la salud, para ser archivadas en la historia clínica física. El auxiliar debe además suministrar al profesional de la salud los formatos de remisiones, recetas médicas, formatos de RIPS y laboratorios.

Como se mencionó al inicio de este punto, en los centros de salud cada coordinador debe comunicarse con el área de sistemas y solicitar información acerca de la falla, para posteriormente socializarla con el personal y los usuarios. Los coordinadores deben verificar que en cada centro de salud se tenga disponible suficiente papelería y que las agendas manuales hayan sido impresas desde el día anterior.

Por su parte el profesional asistencial debe solicitar al paciente la factura manual para verificar que efectivamente la cita se encuentre agendada. Debe diligenciar la historia clínica física en el formato que corresponda a la atención. Debe diligenciar completamente la admisión del paciente en la hoja de evolución y diligenciar el formato de RIPS. El área de bienes y servicios debe proveer los formatos y la papelería correspondiente de acuerdo a las solicitudes realizadas por cada coordinador de centro de salud.

IMPLEMENTACIÓN DE RECUPERACIÓN

A continuación, se muestran los peligros y amenazas a los que está expuesto el sistema de información y se describen las soluciones a los daños causados por su ocurrencia.

IDENTIFICACIÓN DE RIESGOS

Se han determinado los posibles eventos que afectan el buen funcionamiento del sistema de información de la E.S.E, tanto en los equipos, la infraestructura y

los datos. Éstos han sido determinados en cuenta los factores humanos, tecnológicos y medioambientales.

Los que afectan la seguridad o integridad de los equipos:

- Robo de equipos, daños por sabotaje o daños por mal uso.

Los que afectan a la integridad de la infraestructura:

- Corte de energía eléctrica.
- Fugas de agua y humedades.
- Terremoto.
- Incendio.
- Cortes o golpes en el cable UTP o el cable eléctrico.
- Descargas eléctricas en las antenas.
- Sobrecarga en la red eléctrica regulada por conexión de equipos no autorizados.

Los que afectan la integridad de los datos:

- Virus informáticos.
- Desconexión del servidor con el cliente o viceversa.
- Bloqueo en el motor de base de datos.
- Fallas o Pérdida del servidor.
- Pérdida por eliminación de información.
- Sabotaje o daño en software OMEGA o en su servidor.
- Pérdida de la conexión de la internet.

1.1. SOLUCIONES A LOS PROBLEMAS PRESENTADOS

1.1.1. ROBO DE EQUIPOS, DAÑOS POR SABOTAJE O DAÑOS POR MAL USO

Una estación de trabajo es un ordenador que facilita a los usuarios el acceso a los servidores y periféricos de la red. A diferencia de un ordenador aislado, tiene una tarjeta de red y está físicamente conectada con los servidores por medio de cables u otros medios no guiados.

La pérdida, daño total o parcial de una estación de trabajo se puede presentar tanto lógicamente como físicamente esto podría ser debido a:

- Daños producidos en fuente de alimentación por inconvenientes en la energía eléctrica.
- Daños ocasionados en HARDWARE o SOFTWARE por el usuario debido a la mala manipulación.
- Estación de trabajo enciende, pero con un mensaje que dice ERROR DISK BOOT FAILURE.
- Sonidos como beeps al encender.
- Problemas de conexión de red.

Se conoce como sabotaje la destrucción, daño o modificación realizada con el fin de alterar el funcionamiento o causar daño en un sistema que utilice tecnologías de información o cualquiera de los componentes que lo conforman. Incurrirá en la misma falta quien destruya, dañe, modifique o inutilice la información contenida en cualquier sistema que utilice tecnologías de información o en cualquiera de sus componentes.

La oficina de mantenimiento de sistemas se encarga de reparar los daños ocasionados a los terminales de cómputo e informar sobre el evento ocurrido a los funcionarios establecidos. La oficina de activos fijos se encarga de evaluar el costo de los equipos robados e informar a las autoridades competentes y a las aseguradoras.

1.1.2. CORTE DE ENERGÍA ELÉCTRICA

En caso que se presente un corte de energía eléctrica y la planta no soporte todos los circuitos se debe recomendar a todos los usuarios empezar a realizar el apagado de los equipos de cómputo, en especial las maquinas que cumplen la función de servidor, antes de que termine la carga de las respectivas UPS, con el fin de evitar un mal pagado de la máquina que nos puede llevar a presentar daños tanto en el hardware como en la información. Posteriormente se debe informar al proveedor del fluido eléctrico o al área de mantenimiento del hospital, según sea el caso.

1.1.3. FUGAS DE AGUA Y HUMEDADES

Si en la E.S.E se llega a presentar una fuga de agua o humedad detendría las operaciones del área o las áreas donde se presente la emergencia, convirtiéndose en un daño menor o mayor según su ubicación.

Se presentaría un mayor impacto si esta fuga de agua o inundación sucede en la oficina de sistemas de información, porque en ella está ubicado el servidor de aplicaciones y base de datos o en el cuarto de redes, porque en él se albergan todos los dispositivos de red. En los centros de salud se presentaría este mismo problema, si la fuga de agua se presentara en la ubicación del gabinete de comunicaciones.

23

1.1.4. TERREMOTO

Un terremoto, también llamado sismo o temblor de tierra, es una sacudida del terreno que se produce debido al choque de las placas tectónicas y a la liberación de energía en el curso de una reorganización brusca de materiales de la corteza terrestre al superar el estado de equilibrio mecánico.

Este así mismo llamado sismo puede ocasionar daños menores del edificio o pérdida del edificio. En el primer caso, el sistema se restablecería cuando haya pasado la emergencia y se haya normalizado el fluido eléctrico. En caso de colapso de las estructuras, se deben evaluar los daños para poner en marcha una estación de trabajo que se pueda utilizar como servidor alternativo.

1.1.5. INCENDIO

La E.S.E no está exenta en ningún momento que se pueda llegar a presentar un incendio por un corto circuito o por cualquier otro motivo, provocando importantes daños a los sistemas informáticos. En este caso al igual que el terremoto el sistema se restablecería cuando haya pasado la emergencia, después de evaluar los daños y establecer si los servidores pueden seguir operando o se hace necesario implementar una estación alternativa.

1.1.6. CORTES O GOLPES EN EL CABLE UTP O EL CABLE ELÉCTRICO

Los cortes o golpes en el cableado eléctrico o de red pueden ocurrir por errores en la realización de algún trabajo, sabotaje o daños en la estructura del edificio. Para mitigar los efectos de un año de este tipo se deben emplear extensiones eléctricas o de datos según sea el caso, mientras se reemplazan o reparan las líneas; también se pueden reubicar los equipos en puntos cercanos mientras se realizan estas reparaciones.

24

1.1.7. DESCARGAS ELÉCTRICAS EN LAS ANTENAS

Posiblemente una descarga eléctrica en una de las antenas de comunicaciones genere un daño mayor en todo el gabinete de red. En cualquiera de los casos, se debe informar al proveedor de la red de radiofrecuencia para la reparación o reemplazo de los dispositivos afectados.

1.1.8. SOBRECARGA EN LA RED ELÉCTRICA REGULADA POR CONEXIÓN DE EQUIPOS NO AUTORIZADOS

Una sobrecarga en la red eléctrica regulada acciona un breaker o apaga la UPS. En cualquiera de los casos se hace necesario identificar el punto eléctrico donde se produjo el problema, desconectar el dispositivo que lo genera y restablecer el fluido eléctrico en el circuito comprometido.

1.1.9. VIRUS INFORMÁTICOS

Un virus informático es un software malintencionado que tiene por objeto alterar el normal funcionamiento de la computadora, sin el permiso o el conocimiento del usuario. Los virus, habitualmente, reemplazan archivos ejecutables por otros infectados con el código de este. Si el virus que es detectado en uno de los terminales, éste se debe aislar y su sistema operativo se debe restablecer. Si el virus es detectado en uno de los servidores, éste se debe desconectar de la red, se deben revisar las bases de datos y el Estado del sistema operativo; si la afectación es mínima se debe ejecutar una rutina antivirus y si la afectación es mayor, se deben extraer las bases de datos y se debe restablecer el sistema operativo y el motor de bases de

datos. Se debe tener en cuenta extraer la información correspondiente al dominio de usuarios para evitar problemas de autenticación de los terminales.

1.1.10. DESCONEXIÓN DEL SERVIDOR CON EL CLIENTE O VICEVERSA

25

Los problemas de comunicación del cliente con los servidores, los problemas en el cableado eléctrico de las estaciones de trabajo, los problemas con los recursos compartidos de la red y la caída de la base de datos, son eventos que producen un impacto menor para la continuidad de las operaciones en la E.S.E, En estos eventos es necesario analizar la causa que generó la emergencia con el fin de evitar nuevas interrupciones en las labores institucionales, al igual que prevenir daños en la integridad de los datos. A continuación, encontramos las siguientes fallas de la red de datos que pueden causar desconexión del servidor y los clientes:

Desconexión:

Las redes de conexiones directas dependen de una conexión sólida entre las computadoras. Los cables rotos y los conectores gastados interfieren con la transmisión de datos. En el caso de las redes inalámbricas, las señales de radio y la interferencia de obstrucciones metálicas o de otras señales, pueden degradar el rendimiento.

Configuración:

Una red depende de programas que direccionan los datos entre computadoras. Estos programas requieren instrucciones detalladas sobre el funcionamiento de la red. Si el administrador de red o el usuario se equivocan al configurar el software o la configuración es alterada, los datos no se transmitirán correctamente.

Saturación:

El incremento de la exigencia sobre una red, como las descargas excesivas, puede saturar su capacidad, lo que atascará el tránsito para todos. El administrador de red debe hacer un seguimiento a la carga de la red y asegurarse de que su capacidad baste para todos los usuarios.

Ruido:

La interferencia de ruidos radiales y eléctricos puede causar problemas en la transmisión de datos. Si los datos llegan mezclados, las computadoras los

vuelven a enviar. Finalmente, los datos válidos llegarán a su destino, pero las retransmisiones añadirán tráfico a la red y pueden hacerla más lenta.

1.1.11. BLOQUEO EN EL MOTOR DE BASES DE DATOS

Las bases de datos son el servicio principal para almacenar, procesar y proteger los datos. Siempre debemos contar con un motor de base de datos que nos proporciona acceso controlado y procesamiento de transacciones rápido para cumplir con los requisitos de las aplicaciones consumidoras de datos más exigentes de la E.S.E, pero en ocasiones suceden bloqueos por alguna de estas causas:

26

- normalmente pueden ser daños en las estructuras de nuestros índices o almacenamiento físico de nuestros registros.
- se puede dañar por fallas debido a que nuestro servidor se reinicia de manera inesperada o la memoria RAM o el disco duro tienen algunos problemas; Esto origina que en la base de datos se corrompan algunos objetos como tablas o índices.
- Saltos en los procesos de almacenamiento al contenedor asignado.
- Desconexión del proceso cliente servidor que afecta la conectividad a la base de datos, esto puede generar problemas en los índices de entrada y salida.

En cualquiera de estos casos, se debe identificar y corregir el problema, teniendo la precaución de aislar el servidor o informar a los usuarios acerca del proceso que se llevará a cabo, para evitar la pérdida de información.

1.1.12. FALLAS O PÉRDIDA DEL SERVIDOR

El término servidor se utiliza para referirse al ordenador físico en el cual se instalan los aplicativos y las bases de datos, esto con el fin de centralizar la información comportándose como una máquina cuyo propósito es proveer datos de modo que otras máquinas utilizan todo esto gracias a la administración de un sistema operativo propio de servidores.

El servidor puede encontrarse con las siguientes situaciones de pérdida de datos.

- Falla del Controlador RAID o arreglos de discos.
- Reconfiguración accidental de las unidades RAID.
- Pérdida del registro de configuración del sistema operativo.
- Falla de la unidad de memoria virtual lo cual resulta en el colapso de la configuración.
- Falla múltiple de la unidad.
- Eliminación accidental mientras se realiza el respaldo de BD.
- Desastres naturales como incendios, inundaciones o terremotos.

1.1.13. PÉRDIDA POR ELIMINACIÓN DE INFORMACIÓN

La pérdida de información por eliminación premeditada o accidental, debe ser informada al área de sistemas inmediatamente después de su detección. En caso de tratarse de un terminal de cómputo, el usuario debe evitar utilizar el equipo para que el personal del área de sistemas pueda realizar el procedimiento de recuperación de archivos. En caso de tratarse de pérdida de información en alguno de los servidores, el equipo se debe aislar para realizar la respectiva recuperación de archivos. La pérdida de información de unidades magnéticas u ópticas en la mayoría de los casos es irreversible, por la naturaleza propia de los medios de almacenamiento, en el mejor de los casos sólo permite recuperar fragmentos, muchas veces inservibles. La eliminación de archivos en unidades de red o carpetas compartidas posee un alto grado de probabilidad de ser irreversible; en la mayoría de los casos los usuarios de la red han reutilizado los segmentos de memoria en los que se albergaba la información eliminada, por este motivo el proceso de recuperación de archivos puede requerir mucho tiempo de trabajo en el equipo que almacenaba originalmente la unidad compartida. La información eliminada de unidades flash (memorias USB, SD o Micro SD) puede ser recuperada sólo si la unidad de almacenamiento se encuentra en perfecto estado y no ha sufrido cambios después de la eliminación de archivos.

1.1.14. SABOTAJE O DAÑO EN SOFTWARE OMEGA O EN SU SERVIDOR

Las fallas que pudiera presentar el servidor de ROCHE o su sistema de información Omega, deben ser informadas de inmediato a la Coordinadora del laboratorio y/o al área de ingeniería de ROCHE. Esto

se debe hacer siempre, independientemente de la situación que haya generado la falla.

1.1.15. PERDIDA DE LA CONEXIÓN DE LA INTERNET

LA E.S.E cuenta con una conexión de banda ancha a través de un canal dedicado de radio frecuencia con una velocidad de 8 Mbps. El modem del proveedor del servicio se encuentra ubicado en el cuarto de comunicaciones del hospital y acceden a él desde los centros de salud a través a través una red de radio frecuencia punto multipunto. El acceso a internet se administra desde un FIREWALL físico marca cisco cuyo software administrativo se encuentra instalado en la estación de trabajo de la oficina de MANTENIMIENTO DE SISTEMAS. Cuando ocurre una falla o se detecta una caída en el ancho de banda o la señal de Internet, el primer paso es reiniciar los equipos del proveedor. En caso de que el daño persista se debe informar de inmediato al Help Desk o área de apoyo del proveedor del servicio.

28

ESTRATEGIAS DE RECUPERACIÓN

- La estimación del tiempo en que va a durar la interrupción del servicio, se obtiene luego de ejecutar el plan de contingencia y una vez se haya evaluado el alcance de las fallas que se presentaron.
- Si la interrupción del proceso va a ser por largo tiempo luego del desastre o falla, se debe poner en ejecución la planificación e implementación de recuperación
- Un día posterior al desastre se deberán preparar las copias de respaldo del sistema de información, software, bases de datos, aplicaciones y el procedimiento a seguir, en busca del restablecimiento del servicio inicial del procesamiento de datos en el sitio alternativo.

PREVENCIÓN Y SEGURIDAD

Para prevenir la pérdida de información clínica, administrativa o financiera, Red Salud Armenia E.S.E. ha implementado un sistema de copias de seguridad que se llevan a cabo a diario, semanal, quincenal y mensualmente de forma automática. En estas copias de seguridad se incluyen las bases de datos del aplicativo institucional dinámica gerencial .net. Adicionalmente se cuenta con un sistema de copias semanales que incluyen la biblioteca del servidor, las imágenes diagnósticas

y el dominio. Las copias de seguridad semanales, quincenales y mensuales se almacenan en un lugar seguro, en una ubicación alterna a la oficina de sistemas. Adicionalmente se ha tomado como medida de prevención instalar el servidor secundario en el cuarto de comunicaciones de red o en la oficina de mantenimiento de sistemas, como medida preventiva ante la ocurrencia de un siniestro o desastre natural.

La oficina de sistemas ha diseñado, socializado e implementado un conjunto de políticas para el uso de equipos de cómputo, periféricos y dispositivos de red, orientado a establecer directrices que minimicen las fallas por mal uso y a fomentar en los usuarios del sistema informático, conductas apropiadas en los puestos de trabajo.

ACTIVACIÓN DE PROCESOS MANUALES

Tal cómo se mencionó en el numeral 11 de este plan de contingencia, se han establecido una serie de procesos manuales que se llevan a cabo en caso de una falla total o parcial en el sistema informático. Los procesos manuales establecidos para los centros de salud y los servicios de la institución, incluyen la utilización de un conjunto de formatos de registro cuya pertinencia y eficacia han sido evaluadas por varios años. A continuación, se presenta una lista de los formatos de registro utilizados según el área donde se requieran.

Área de facturación:

- Hoja de evolución.
- Formato de RIPS.
- Formato de remisiones.
- Formato de recetarios médicos.
- Formato de ayudas diagnósticas.
- Talonario de facturación.

Área asistencial:

- Hoja de evolución.
- Hoja de enfermería.
- Hoja de tratamiento.
- Hoja de órdenes médicas.
- Hoja de signos vitales.
- Hoja de diagnóstico o exámenes auxiliares.
- Hoja de epicrisis.
- Hoja de remisión.
- Hoja de glucometría.

- Hoja de saturación de oxígeno.
- Hoja de riesgo de caída.
- Hoja neurológica.
- Hoja descripción quirúrgica.
- Hoja de récord “control” de anestesia.
- Partograma, CLAP.
- Kárdex para el cuidado de enfermería.
- Kárdex de medicamentos.
- Recetario médico.

Estos formatos de registro han sido establecidos por los líderes de proceso.

Control de cambios

Versión	Fecha de actualización	Razón de la actualización
1	15/10/2021	